

Enhanced Attack Report

Cheeky Chipmunk

Generated on 2025-10-12

Disclaimer

This report has been generated automatically and should be used for informational purposes only. To generate this report, Large Language Models (LLMs) were used to analyze the provided data. This technology is not perfect and may generate incorrect or misleading results. The results should be reviewed by a human expert before taking any action based on the information provided.

Definitions

Pre-Conditions: Conditions that must be true to execute the attack steps in the milestone.

Post-Conditions: Traces that an attacker leaves behind after executing the attack steps in the milestone.

Attack Steps: Steps that an attacker would take to achieve the goal of the milestone.

MITRE Technique: Techniques from the MITRE ATT&CK; framework that are relevant to the milestone.

STIX

Malware Name: Cheeky Chipmunk

Malware Description: Cheeky Chipmunk is a malicious Microsoft Windows Remote Procedure Call (RPC) server, installed via a PowerShell loader. Command and control (C2) is performed using a separate standalone executable RPC client. The loader implements an Antimalware Scanning Interface (AMSI) avoidance technique and is protected using layered obfuscation, encryption and compression. Functionality includes execution of shell commands and upload/download of files. The RPC connection is set up using named pipes, for which numerous names have been observed across multiple versions of Cheeky Chipmunk. Cheeky Chipmunk is added as a Windows service to maintain persistence.

Quick Overview

Milestone m1

- a1. Command and Scripting Interpreter: PowerShell as used by the malware (T1059.001)
- a2. Command and Scripting Interpreter: Windows Command Shell as used by the malware (T1059.003)
- a3. Inter-Process Communication: Component Object Model as used by the malware (T1559.001)
- a4. Windows Management Instrumentation as used by the malware (T1047)

Milestone m2

- a5. Create or Modify System Process: Windows Service as used by the malware (T1543.003)

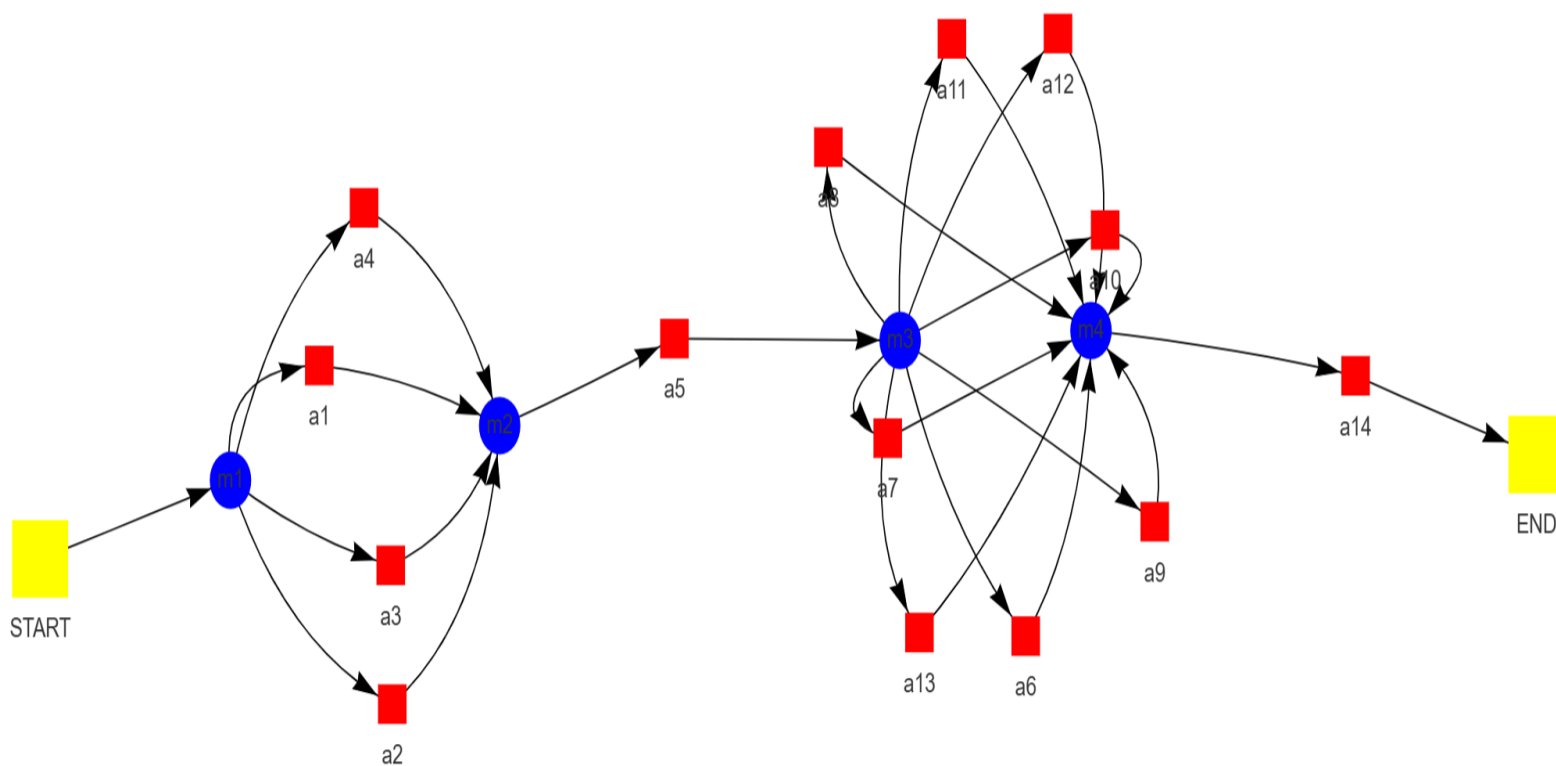
Milestone m3

- a6. Deobfuscate/Decode Files or Information as used by the malware (T1140)
- a7. Indicator Removal on Host: File Deletion as used by the malware (T1070.010)
- a8. Indicator Removal on Host: File Deletion as used by the malware (T1070.004)
- a9. Masquerading: Match Legitimate Name or Location as used by the malware (T1036.005)
- a10. Masquerading: Match Legitimate Name or Location as used by the malware (T1036.005)
- a11. Masquerading: Match Legitimate Name or Location as used by the malware (T1036.005)
- a12. Obfuscated Files or Information as used by the malware (T1027)
- a13. Impair Defenses: Disable or Modify Tools as used by the malware (T1562.001)

Milestone m4

- a14. Data from Local System as used by the malware (T1005)

Attack Graph



Milestone *m1*

Attack Step *a1*

=====

Name: Command and Scripting Interpreter: PowerShell as used by the malware

Description: The analysis presented offers a comprehensive overview of the techniques employed by the examined malware. Key techniques identified include: * **CLR Hosting (Managed Code Execution):** Malicious code is executed within memory utilizing the .NET Common Language Runtime (CLR), potentially evading detection by conventional antivirus solutions. This tactic is frequently observed in advanced persistent threats (APTs) due to its inherent stealth and ability to circumvent security measures. * **Registry-Based Command Execution:** Commands are stored within the Windows registry, likely to evade detection by signature-based security tools. PowerShell serves as the scripting engine, enabling flexible and dynamic command execution. Analysis highlights reveal: * **Process Monitoring:** The malware actively monitors for the presence of "explorer.exe" to ascertain system operability prior to executing malicious activities. This suggests a sophisticated approach aimed at avoiding detection during early infection stages. * **Null Session Pipe Exploitation:** The utilization of Null Session Pipes (anonymous pipes) facilitates communication with other systems on the network without requiring explicit authentication. This technique can be employed for lateral movement and command-and-control communication. Potential impacts associated with this malware include: * **Data Exfiltration:** The capability to download and upload files suggests a potential for sensitive information theft from compromised systems. * **Remote Code Execution (RCE):** The "execute" command grants attackers the ability to remotely execute arbitrary code on infected machines, potentially leading to

complete system control. Further investigation is recommended to comprehensively understand this malware: * **Network Traffic Analysis:** Examination of network traffic patterns can identify communication with potential command-and-control servers and compromised systems. * **Registry Key Examination:** Thorough analysis of registry keys used by the malware for storing commands and configuration information should be conducted, focusing on unusual entries or modifications that may reveal its purpose. * **Code Disassembly:** Analysis of the malware's assembly code can elucidate specific functions, data structures, and control flow patterns, providing insights into its behavior and functionality. * **Sandbox Analysis:** Execution of the malware within a controlled sandbox environment allows for observation of its actions and system interactions without compromising the security of the analyst's machine.

Pre-Conditions:

- The .NET Framework is installed on the target machine.
- Environment: A compromised Windows system with administrative privileges.
- A Windows operating system is present.
- Connectivity: Not explicitly stated, but potential for network communication to download additional payloads or communicate with a command-and-control server.
- Tools: The malware executable containing the PowerShell script.
- Resources: Access to system resources such as memory and processor time.
- The malware has successfully loaded and executed its code.

Post-Conditions:

- Potential damage to system functionality and stability.
- Network connections to command and control servers.
- Evidence of executed malicious code.
- Persistence mechanism established for future malicious activity.
- Compromised system with potential data exfiltration.
- New files created in non-standard locations (e.g., %TEMP%, AppData).
- Altered system logs with suspicious activity.
- Modified or deleted original files.
- Modified registry entries.

MITRE Technique

ID: T1059.001

Name: Command and scripting interpreter: powershell

Description: Adversaries may abuse PowerShell commands and scripts for execution. PowerShell is a powerful interactive command-line interface and scripting environment included in the Windows operating system. Adversaries can use PowerShell to perform a number of actions, including discovery of information and execution of code. Examples include the Start-Process cmdlet which can be used to run an executable and the Invoke-Command cmdlet which runs a command locally or on a remote computer (though administrator permissions are required to use PowerShell to connect to remote systems).

More info: <https://attack.mitre.org/techniques/T1059/001>

Attack Step a2

=====

Name: Command and Scripting Interpreter: Windows Command Shell as used by the malware

Description: The Windows Command Shell is integrated into the Cheeky Chipmunk malware framework for remote execution capabilities. Upon client connection, commands are received by the RPC server and executed within a launched instance of cmd.exe. These commands enable actions such as file manipulation, system information retrieval, process control, and network activity on the infected machine. Communication between the client and server is facilitated through named pipes. The use of the Windows Command Shell for remote execution presents security risks including arbitrary code execution, privilege escalation, and potential stealth due to named pipe communication.

Pre-Conditions:

- The system is running a Windows operating system.
- A command shell interface is accessible.

Post-Conditions:

- A Cheeky Chipmunk RPC server is running on the system.
- Network connections to C&C; servers for receiving further instructions or exfiltrating data.
- Modified system files or registry keys reflecting changes made by the payload.
- The system has a persistence mechanism ensuring the RPC server restarts after reboots.
- Registry entries related to the persistence mechanism.
- A malicious payload is executed and potentially performs harmful actions.
- Logs in %PUBLIC%\NTuser.log indicating successful execution of commands or internal error codes.

MITRE Technique

ID: T1059.003

Name: Command and scripting interpreter: windows command shell

Description: Adversaries may abuse the Windows command shell for execution. The Windows command shell (cmd) is the primary command prompt on Windows systems. The Windows command prompt can be used to control almost any aspect of a system, with various permission levels required for different subsets of commands. The command prompt can be invoked remotely via Remote Services such as SSH.

More info: <https://attack.mitre.org/techniques/T1059/003>

Attack Step a3

=====

Name: Inter-Process Communication: Component Object Model as used by the malware

Description: Waterbug malware is characterized as a sophisticated and persistent threat actor distinguished by its adaptable tactics and utilization of custom tools. Activities attributed to Waterbug can be categorized into three distinct campaigns, each employing unique toolsets. Campaign 1 (Neptun) leverages a custom backdoor designated Neptun, facilitating passive command-and-control (C2) communication. This backdoor resides on Microsoft Exchange servers and possesses the capability to download tools, upload data, and execute commands. Notably, this campaign potentially utilized infrastructure belonging to another group, Crambus, for purposes of confusion or opportunistic exploitation. Campaign 2 employs Meterpreter, a publicly available backdoor, in conjunction with custom loaders (photobased.dll) and an RPC backdoor. Meterpreter is encoded as a .wav file for the purpose of disguising its true nature. Campaign 3 deploys a unique RPC backdoor that leverages code from PowerShellRunner to execute PowerShell scripts without utilizing the standard powershell.exe process, aiming to evade detection mechanisms. The development of custom malware tools tailored to

specific objectives is a notable characteristic of Waterbug's operations. This includes Neptun, photobased.dll, and various RPC backdoors. Exploitation of vulnerabilities in Microsoft Exchange servers is a prominent tactic employed by Waterbug, underscoring the critical importance of patching and securing these systems. Evasive techniques, such as encoding Meterpreter as a .wav file and utilizing PowerShellRunner to bypass detection mechanisms, are also observed. Analysis indicates that the malware's RPC server utilizes Component Object Model (COM) for calling embedded PowerShell runner code. This suggests the exploitation of legitimate Windows features like COM for malicious purposes, thereby making detection more challenging due to its integration with normal system activity. The use of PowerShell runner likely enables dynamic code execution and command scripting, enhancing flexibility and adaptability. In conclusion, Waterbug represents a highly skilled threat actor that continuously refines its tactics and tools. The emphasis on custom backdoors, vulnerability exploitation, and evasive techniques positions Waterbug as a significant cybersecurity concern. Organizations are urged to prioritize system patching, implement robust security controls, and maintain awareness of emerging threats to effectively mitigate the risks posed by Waterbug and other advanced persistent threats (APTs).

Pre-Conditions:

- A Windows operating system is required.
- The malware executable must be present on the target system.
- The malware possesses the necessary code to interact with the Component Object Model (COM).
- The malware has successfully loaded the "mscoree.dll" file.
- A target system with a .NET Framework installation is present.
- Network connectivity may be required for communication between the malware and its command-and-control server, depending on the specific implementation.

Post-Conditions:

- New Windows service named "Peer Name Resolution Provider".
- A Windows service is created running the Cheeky Chipmunk RPC server.
- The loader script (mstcf.ps1) is forcibly removed from disk.
- Registry entries related to the new service and log file.
- A file named "securlsa.chk" containing the Base64-encoded Cheeky Chipmunk RPC server binary is written to C:\Windows\security\database.
- Log file named "NTuser.log" created in the system directory.

MITRE Technique

ID: T1559.001

Name: Inter-process communication: component object model

Description: Adversaries may use the Windows Component Object Model (COM) for local code execution. COM is an inter-process communication (IPC) component of the native Windows application programming interface (API) that enables interaction between software objects, or executable code that implements one or more interfaces. Through COM, a client object can call methods of server objects, which are typically binary Dynamic Link Libraries (DLL) or executables (EXE). Remote COM execution is facilitated by Remote Services such as Distributed Component Object Model (DCOM).

More info: <https://attack.mitre.org/techniques/T1559/001>

Attack Step a4

=====

Name: Windows Management Instrumentation as used by the malware

Description: Windows Management Instrumentation (WMI) is a technology integral to Windows operating systems, facilitating applications' querying and management of system information, hardware configurations, installed software, and related data. WMI operates on a client-server architecture. Clients, such as applications, submit requests to the WMI server for specific data. The WMI service, running on the Windows machine, processes these requests and returns the requested information. Malicious actors may exploit WMI's Remote Procedure Call (RPC) functionality for nefarious purposes. Malware can establish an RPC server on a compromised system, registering itself with designated interfaces and protocols. This enables other malicious programs to connect as clients and execute commands. WMI serves as the communication channel for this malware-controlled RPC server. Instead of conventional network sockets or pipes, the malware leverages WMI's existing infrastructure. The utilization of WMI by malware presents several security risks. Its integration with legitimate system processes can render detection by security tools challenging, as malicious activity may appear indistinguishable from normal operations. Furthermore, registering as an RPC server allows for potential persistence on the compromised system, even after system reboots.

Pre-Conditions:

- The malware has successfully executed its initial stages.
- The malware has access to the necessary system resources.
- The malware possesses the required permissions to interact with WMI.
- A running instance of the Windows Management Instrumentation (WMI) service.
- A Windows operating system is present.

Post-Conditions:

- Compromised system with persistent backdoor access.
- Event log entries indicating suspicious activity, such as unauthorized process creation, file modifications, and network connections.
- Data exfiltration to attacker-controlled servers.
- Modified registry entries related to service installation and execution.
- Modified system files containing malicious code or altered configurations.
- System instability and performance degradation.
- Network traffic logs showing communication with attacker-controlled servers for command and control, data transfer, and potential lateral movement.
- Potential for further malware infections and lateral movement within the network.
- Loss of sensitive information and intellectual property.
- New files containing the Neptun backdoor binary and associated configuration files.

MITRE Technique

ID: T1047

Name: Windows management instrumentation

Description: Adversaries may abuse Windows Management Instrumentation (WMI) to execute malicious commands and payloads. WMI is designed for programmers and is the infrastructure for management data and operations on Windows systems. WMI is an administration feature that provides a uniform environment to access Windows system components.

More info: <https://attack.mitre.org/techniques/T1047/>

Milestone *m2*

Attack Step *a5*

=====

Name: Create or Modify System Process: Windows Service as used by the malware

Description: A Windows service designated as "pnrssp" is created by the malware following the execution of its initial payload and subsequent tasks. This service is configured to initiate automatically upon system startup, ensuring continuous operation of the malware's RPC server even after user logoff or system restarts. The Windows service functions as a persistent container for the malware's core functionality, continuously monitoring for commands from external clients and executing them accordingly. This operational loop maintains Cheeky Chipmunk's active presence on infected systems until manual removal or detection by security software occurs. The utilization of a Windows service for persistence is attributed to its inherent capabilities: system-level execution with elevated privileges, automatic startup functionality, and stealth characteristics that facilitate blending with legitimate system processes.

Pre-Conditions:

- The malware has successfully gained control of a target system running Windows.
- The malware possesses the necessary code to construct and execute a new service or modify an existing one.
- A functioning Windows operating system is present.

Post-Conditions:

- Compromised system with persistent backdoor access.
- Log entries indicating suspicious activity.
- System instability and performance degradation.
- Potential for further malware installation and execution.
- Altered system configurations.
- Data exfiltration to remote server(s).
- Network connections to unknown C&C; servers.
- New files created in %PUBLIC% directory.
- Modified registry entries.

MITRE Technique

ID: T1543.003

Name: Create or modify system process: windows service

Description: Adversaries may create or modify Windows services to repeatedly execute malicious payloads as part of persistence. When Windows boots up, it starts programs or applications called services that perform background system functions. Windows service configuration information, including the file path to the service's executable or recovery programs/commands, is stored in the Windows Registry.

More info: <https://attack.mitre.org/techniques/T1543/003>

Milestone *m3*

Attack Step *a6*

=====

Name: Deobfuscate/Decode Files or Information as used by the malware

Description: CLR hosting is exploited by malware for malicious purposes. Code execution can be performed in memory by malware leveraging the Common Language Runtime (CLR). This process circumvents traditional antivirus scans that primarily focus on files stored on disk. Security measures may prove ineffective against code executed within the secure sandbox provided by the CLR. Malware utilizes techniques such as LoadLibrary to load the mscoree.dll file, which is essential for CLR functionality. APIs provided by mscoree.dll are then employed to create an instance of the CLR runtime environment, specifying the desired .NET framework version. Malicious .NET code, typically a compiled assembly file (.dll or .exe), is loaded into memory and executed within the sandboxed environment provided by the CLR. Analysis of malware samples reveals techniques such as GetProcAddress for resolving addresses of required Windows APIs at runtime, hindering detection by obscuring the specific functions utilized. Decryption and decoding of malicious .NET code prior to loading it into memory are also common obfuscation techniques employed by malware. The utilization of CLR hosting presents significant security implications. Malware authors can leverage this technique to evade signature-based detection methods reliant on file analysis. Persistence is facilitated through the creation of processes that run in memory, making removal more challenging. The dynamic modification of code executed within the CLR sandbox further complicates analysis and detection efforts.

Pre-Conditions:

- A computer system with sufficient processing power and memory.
- The malware utilizes encryption, encoding, and compression techniques.
- Access to the obfuscated files or information is required.
- A suitable deobfuscation/decoding tool capable of handling various techniques like single-byte XOR encoding, encryption, encoding, and compression.
- The specific algorithms used for these techniques are unknown.
- Knowledge of potential algorithms used for obfuscation (may require research).

Post-Conditions:

MITRE Technique

ID: T1140

Name: Deobfuscate/decode files or information

Description: Adversaries may use Obfuscated Files or Information to hide artifacts of an intrusion from analysis. They may require separate mechanisms to decode or deobfuscate that information depending on how they intend to use it. Methods for doing that include built-in functionality of malware or by using utilities present on the system.

More info: <https://attack.mitre.org/techniques/T1140/>

Attack Step *a7*

=====

Name: Indicator Removal on Host: File Deletion as used by the malware

Description: A detailed technical analysis has been conducted on a malware sample designated as "Cheeky Chipmunk." The analysis elucidates its utilization of CLR hosting for the execution of PowerShell payloads, thereby circumventing conventional antivirus detection mechanisms. The malware exhibits capabilities encompassing CLR hosting, Remote Procedure Calls (RPC) communication, and file manipulation functionalities. Technical examination reveals that the malware analyzes installed .NET framework versions (v2 and v4) on the target system and dynamically loads the corresponding version of mscoree.dll. Subsequently, functions such as CorBindToRuntime and CLRCreateInstance are employed to establish a CLR instance and execute managed code, specifically PowerShell scripts. PowerShell scripts are either embedded within the malware binary or downloaded from a command-and-control server. These scripts are executed within the secure environment provided by the CLR, thereby enhancing evasion capabilities. Attribution analysis suggests an association between this malware and the threat actor group known as "Waterbug." "Waterbug" has been observed employing diverse tools and techniques across multiple campaigns targeting organizations globally. The utilization of CLR hosting presents a significant security implication, enabling malware to bypass traditional signature-based detection methods by executing code within the trusted environment of the .NET framework. The implementation of RPC for communication grants attackers the ability to remotely control infected systems and execute commands. Furthermore, data exfiltration from compromised systems to the command-and-control server is facilitated by the malware. Mitigation strategies encompass robust endpoint security solutions incorporating behavioral analysis and exploit mitigation techniques. Network monitoring for suspicious activity, such as communication with known malicious IP addresses or domains, is crucial. Maintaining up-to-date operating systems and software applications through timely patching helps mitigate vulnerabilities that malware could exploit. Security awareness training programs are essential to educate users about the risks associated with phishing attacks and other social engineering techniques employed by attackers to gain initial access to systems.

Pre-Conditions:

- The malware has identified the file(s) it wants to delete.
- The malware has successfully infected the target system.

Post-Conditions:

MITRE Technique

ID: T1070.010

Name: Indicator removal: relocate malware

Description: Once a payload is delivered, adversaries may reproduce copies of the same malware on the victim system to remove evidence of their presence and/or avoid defenses. Copying malware payloads to new locations may also be combined with File Deletion to cleanup older artifacts.

More info: <https://attack.mitre.org/techniques/T1070/010>

Attack Step a8

=====

Name: Indicator Removal on Host: File Deletion as used by the malware

Description: A malware sample designated as "Cheeky Chipmunk" has been subjected to detailed analysis. The primary objective of this malware appears to be the establishment of an RPC server for communication with external malicious components or command-and-control infrastructure. Analysis

techniques employed include CLR hosting, facilitating the execution of a custom .NET binary containing core functionalities, potentially evading detection by mimicking legitimate applications. Null Session Pipes are leveraged for communication with remote systems, potentially circumventing authentication mechanisms. Additionally, a modified version of the open-source PowerShellRunner tool is utilized to execute PowerShell scripts without directly invoking powershell.exe, further obscuring malicious activities. The analysis process commenced with an examination of the DLL's entry point (DllMain) and progressed to the ServiceMain function, where crucial strings were extracted. A handle to a .NET runtime (version 2 or 4) was retrieved using specific API calls, essential for executing the custom .NET binary. Subsequently, the managed code was loaded into memory and executed, likely triggering the malware's core functionality. File deletion, specifically of a log file containing details regarding the RPC server's execution after exfiltration, was observed. This action is classified as "Indicator Removal on Host," a technique employed by malware to hinder analysis and forensic investigations. The identified techniques highlight sophisticated methods for evading detection, establishing persistent connections, and executing malicious code.

Pre-Conditions:

- The malware possesses knowledge of the file path to be deleted.
- The malware has successfully executed and is running on the target host.

Post-Conditions:

- Deleting all browser history."
- Running the downloaded file.
- Downloading a file from a suspicious website.

MITRE Technique

ID: T1070.004

Name: Indicator removal: file deletion

Description: Adversaries may delete files left behind by the actions of their intrusion activity. Malware, tools, or other non-native files dropped or created on a system by an adversary (ex: Ingress Tool Transfer) may leave traces to indicate to what was done within a network and how. Removal of these files can occur during an intrusion, or as part of a post-intrusion process to minimize the adversary's footprint.

More info: <https://attack.mitre.org/techniques/T1070/004>

Attack Step a9

=====

Name: Masquerading: Match Legitimate Name or Location as used by the malware

Description: This analysis provides a comprehensive overview of the Cheeky Chipmunk malware and its characteristics. Key aspects covered include its purpose (remote code execution), communication mechanism (RPC), command structure, and potential evasion techniques (legitimate service path). Technical details regarding the utilization of PowerShellRunner for script execution and reliance on mscorere.dll for CLR hosting are presented, demonstrating a thorough understanding of malware behavior. Attribution is established by connecting Cheeky Chipmunk to the Waterbug group, highlighting their history of campaigns and tool development. The mention of the Crambus connection provides valuable context regarding potential overlaps or diversions in attacks. Specific examples of obfuscated code snippets or command structures would further strengthen the analysis. A discussion on the potential consequences of a successful Cheeky Chipmunk infection, including the types of data

that could be compromised and the actions attackers could take on infected systems, is recommended. Practical advice on mitigation strategies, such as regular security updates for operating systems and software, multi-factor authentication (MFA) to secure accounts, network segmentation to limit lateral movement within a network, implementation of Security Information and Event Management (SIEM) systems to detect suspicious activity, and employee training on phishing awareness and safe browsing practices, would be beneficial. The analysis accurately describes how Cheeky Chipmunk utilizes a legitimate Windows service path ("netsvcs") to maintain persistence, aiding in its avoidance of detection by security software that might flag unusual processes.

Pre-Conditions:

- The malware has the capability to modify its own name or location.

Post-Conditions:

MITRE Technique

ID: T1036.005

Name: Masquerading: match legitimate resource name or location

Description: Adversaries may match or approximate the name or location of legitimate files, Registry keys, or other resources when naming/placing them. This is done for the sake of evading defenses and observation.

More info: <https://attack.mitre.org/techniques/T1036/005>

Attack Step a10

=====

Name: Masquerading: Match Legitimate Name or Location as used by the malware

Description: A multifaceted approach is employed by the Waterbug threat actor group, as evidenced by the analysis. Tool diversity is exhibited through the utilization of both custom malware, such as Neptun and PhotoBased, and publicly available backdoors (Meterpreter) and legitimate administration tools (PsExec). This adaptability complicates detection and tracking efforts. An increasing reliance on PowerShell scripts and PsExec aligns with the "living off the land" paradigm, wherein readily available system utilities are repurposed for malicious activities, thereby blending in with legitimate operations. Three distinct campaigns have been identified, each employing unique toolsets, suggesting a strategic approach to targeting specific victims or objectives. The exploitation of Crambus's infrastructure for their own purposes demonstrates Waterbug's opportunistic nature and willingness to leverage existing vulnerabilities. Technical analysis reveals the existence of custom backdoors, such as Neptun, designed for passive listening and command execution on Exchange servers, highlighting their capability in developing sophisticated malware tailored to specific targets. XOR-encoded function names and module names within the malware analysis point towards efforts aimed at concealing malicious intent from security researchers and detection systems. Enhanced threat intelligence is crucial for organizations to remain informed about Waterbug's evolving tactics, tools, and targets through vulnerability assessments and threat intelligence feeds. Strengthening the security posture through robust endpoint protection, network segmentation, and multi-factor authentication can help mitigate the risks posed by Waterbug and other sophisticated attackers. Continuous monitoring of system logs, network traffic, and user activity is essential for detecting suspicious behavior and potential intrusions at an early stage.

Pre-Conditions:

- The malware must have knowledge of legitimate file names and locations within the target system.

Post-Conditions:

- Modified system registry entries.
- System performance degradation due to malware activity.
- Potential for further attacks and lateral movement within the network.
- Obfuscated files with malicious code hidden in legitimate file names or locations.
- Data exfiltration to remote server controlled by attacker.
- New user accounts created with elevated privileges.
- Deleted log files or altered timestamps to conceal malicious activity.
- Compromised system with persistent malware infection.
- Network traffic logs showing communication with attacker-controlled servers.
- Unusual process activity and resource consumption patterns.

MITRE Technique

ID: T1036.005

Name: Masquerading: match legitimate resource name or location

Description: Adversaries may match or approximate the name or location of legitimate files, Registry keys, or other resources when naming/placing them. This is done for the sake of evading defenses and observation.

More info: <https://attack.mitre.org/techniques/T1036/005>

Attack Step a11

=====

Name: Masquerading: Match Legitimate Name or Location as used by the malware

Description: This document presents an in-depth analysis of the Cheeky Chipmunk malware and the Waterbug threat actor group. The Cheeky Chipmunk malware is characterized as a remote access trojan (RAT) designed for espionage and data exfiltration purposes. Its functionality encompasses the capability to upload and download executables to/from infected machines, execute commands remotely on infected systems, and exfiltrate data from compromised machines. Communication between the malware client and server is facilitated through a Remote Procedure Call (RPC) mechanism. The Waterbug threat actor group is attributed as a sophisticated, state-sponsored entity believed to operate from China. Primary targets encompass government agencies, think tanks, and private companies across diverse sectors. The group's tactics, techniques, and procedures (TTPs) involve the utilization of a wide array of tools and techniques, including custom malware, modified open-source tools, and living-off-the-land methods. Spear phishing campaigns are employed to deliver initial access, while stolen credentials are leveraged for lateral movement within networks. A focus on long-term persistence and data exfiltration is observed. Key observations indicate that Waterbug demonstrates a high level of technical sophistication and adaptability, continuously evolving its toolset and tactics. Campaigns frequently involve multi-phased operations and intricate infrastructure setups. A clear preference for espionage over direct disruption or financial gain is exhibited by the group. Recommendations are provided to organizations seeking to mitigate the risks posed by Waterbug. These include the implementation of robust security measures such as multi-factor authentication (MFA) for all user accounts, regular security awareness training for employees, network segmentation and access controls, intrusion detection and prevention systems (IDS/IPS), endpoint detection and response (EDR) solutions, and incident response planning and testing. Further research is encouraged to remain informed about the latest Waterbug activity and developments through threat intelligence feeds and security blogs. Network traffic analysis for suspicious activity, such as communication with

known malicious domains or IP addresses, is recommended. Regular vulnerability assessments and penetration testing are suggested to identify weaknesses in defensive postures.

Pre-Conditions:

- Pre-Conditions:
- The malware has access to a list of legitimate names or locations.
- Requirements:
- The malware must have the capability to alter its own identifying characteristics (e.g., file name, process name, network traffic).

Post-Conditions:

- Modified registry keys.
- Data exfiltration to attacker's C&C; servers.
- Persistence on the system through backdoors and scheduled tasks.
- Log files containing command execution details.
- Potential for further lateral movement within the network.
- Deleted or modified original files.
- Altered system configurations.
- New user accounts created.
- Unusual process activity in event logs.
- Compromised system with full control by attacker.
- Backdoor executables and scripts.

MITRE Technique

ID: T1036.005

Name: Masquerading: match legitimate resource name or location

Description: Adversaries may match or approximate the name or location of legitimate files, Registry keys, or other resources when naming/placing them. This is done for the sake of evading defenses and observation.

More info: <https://attack.mitre.org/techniques/T1036/005>

Attack Step a12

=====

Name: Obfuscated Files or Information as used by the malware

Description: Cheeky Chipmunk malware utilizes XOR encryption to obfuscate imported function names. This technique involves the bitwise XOR operation applied to each character of the original function name using the key 0x55. The resulting encrypted representation is then stored within the malware's code. Upon execution, Cheeky Chipmunk performs the reverse XOR operation on these encrypted names, revealing the original function names for utilization. This obfuscation strategy presents challenges for security analysis by hindering immediate identification of malicious code and complicating the understanding of the malware's functionality. Decryption of these function names is a prerequisite for effective reverse engineering, enabling analysts to discern the malware's execution flow and intended actions.

•

Pre-Conditions:

Post-Conditions:

- Temporary files containing command output.
- Persistence on the victim machine through a Windows service.
- Registry keys related to the malware and its persistence mechanism.
- Files uploaded to the RPC server.
- Log entries in %PUBLIC%\NTuser.log.
- Local files modified or created based on commands executed by the malware.
- Modified or new files on the victim machine.
- Network connections to the RPC server.
- Data exfiltrated from the victim machine.
- New Windows service installed.

MITRE Technique

ID: T1027

Name: Obfuscated files or information

Description: Adversaries may attempt to make an executable or file difficult to discover or analyze by encrypting, encoding, or otherwise obfuscating its contents on the system or in transit. This is common behavior that can be used across different platforms and the network to evade defenses.

More info: <https://attack.mitre.org/techniques/T1027/>

Attack Step a13

=====

Name: Impair Defenses: Disable or Modify Tools as used by the malware

Description: While the provided text elucidates various tactics and tools employed by Waterbug, specific methodologies concerning the disabling or modification of security instruments such as AMSI are not explicitly detailed. However, based on prevalent malware behavior and established AMSI bypass techniques, potential avenues for such actions include: function hooking to intercept and manipulate analysis processes; code injection into processes interacting with AMSI, thereby altering their behavior or functionality; manipulation of registry settings associated with AMSI, potentially leading to its disabling or configuration to disregard specific threats; and exploitation of vulnerabilities within kernel-level drivers utilized by AMSI to achieve control and disable its operation. To ascertain concrete details regarding Waterbug's AMSI bypass techniques, recourse should be taken to specialized security research reports, analysis of Waterbug samples through reverse engineering, and monitoring of threat intelligence feeds for real-time information on emerging threats and their tactics.

Pre-Conditions:

- Knowledge of the operating system and its security configurations.
- Pre-Conditions:
- Requirements:
- Potential need for elevated privileges (administrator access) to modify critical system components.
- Access to the target system where the malware is running.
- Tools capable of modifying system settings, processes, or files.
- The malware utilizes tools that can be disabled or modified.

Post-Conditions:

- Compromised system with persistent backdoor access.

- Registry key modifications related to service installation and null session access.
- Network connections to remote command-and-control servers.
- System instability and performance degradation.
- Potential for further malware infections and lateral movement within the network.
- Data exfiltration to remote server(s).
- Traces of data exfiltration in system logs or network traffic analysis.
- New files created by the malware, including backdoor executables and configuration files.
- Log entries indicating suspicious activity, such as process creation, file access, and network communication.
- Loss of sensitive information and intellectual property.
- Altered system files or registry settings indicative of malware infection.

MITRE Technique

ID: T1562.001

Name: Impair defenses: disable or modify tools

Description: Adversaries may modify and/or disable security tools to avoid possible detection of their malware/tools and activities. This may take many forms, such as killing security software processes or services, modifying / deleting Registry keys or configuration files so that tools do not operate properly, or other methods to interfere with security tools scanning or reporting information. Adversaries may also disable updates to prevent the latest security patches from reaching tools on victim systems.

More info: <https://attack.mitre.org/techniques/T1562/001>

Milestone *m4*

Attack Step *a14*

=====

Name: Data from Local System as used by the malware

Description: Data collection techniques employed by malware such as Cheeky Chipmunk involve various methods. File access may be achieved through direct reading of file contents on the victim's hard drive or scheduled scans targeting specific directories for sensitive information based on file extensions or keywords. Registry manipulation encompasses reading values stored in the Windows Registry, which often contain user credentials, application settings, and system-related data. Malware may also modify registry entries to conceal its presence, alter system behavior, or redirect processes. Network communication facilitates data exfiltration by transmitting stolen data to a command-and-control (C&C;) server controlled by attackers, typically using encrypted channels for evasion. Lateral movement through network connections enables malware to spread to other devices on the same network, expanding its potential for data theft. Keylogging capabilities allow malware to record every keystroke made by the user, capturing sensitive information such as passwords, credit card numbers, and personal messages. Indicators of Compromise (IOCs) suggestive of Cheeky Chipmunk or similar malware activity may include unusual file activity, such as the appearance of new files with suspicious names in unexpected locations, frequent modifications of files, or large data transfers to or from the system. Registry changes might involve newly created keys or values related to unknown processes or services, or modifications to existing entries that appear out of place. Network traffic anomalies may manifest as unusually high network activity, particularly to unfamiliar IP addresses, connections to known malicious domains or C&C; servers, or data transmission in encrypted form. Performance degradation symptoms could include slow system performance, frequent crashes, application errors, high CPU or memory usage by unknown processes.

Pre-Conditions:

- The malware has successfully executed on the target system.
- The target system is running a Windows operating system.
- The malware has necessary permissions to access local system data.
- A compromised Windows system with active network connectivity.

Post-Conditions:

- Potential for further malicious activity on compromised system.
- Network connections to remote servers.
- Log files containing PowerShell script output.
- System event logs with suspicious events.
- Compromised system with persistent malware.
- System instability and performance degradation.
- Unusual process activity and memory usage.
- Data exfiltration to remote server(s).
- New files created in %TEMP% directory.
- Modified registry entries.
- Traces of deleted files.

MITRE Technique

ID: T1005

Name: Data from local system

Description: Adversaries may search local system sources, such as file systems, configuration files, local databases, or virtual machine files, to find files of interest and sensitive data prior to Exfiltration.

More info: <https://attack.mitre.org/techniques/T1005/>